

Chapter 3 – Authentication and Authorization

Learning Objectives

After completing this chapter, you should be able to:

- Understand Identity, Authentication, and Authorization.
 - Explain the complete Google Workspace login process.
 - Differentiate Authentication from Authorization.
 - Understand how policies affect access.
 - Troubleshoot login issues using a structured approach.
 - Explain the relationship between Identity Providers (IdPs) and Service Providers (SPs).
-

1. Introduction

Every time a user signs into Google Workspace, several checks occur before access is granted.

Many administrators believe logging in is a single step.

In reality, multiple security layers work together.

Example:

Rahul opens Gmail.

Before Gmail loads, Google evaluates:

- Does the user exist?
- Is the password correct?
- Is MFA required?
- Is the account suspended?
- Is SAML configured?
- Is the user authorized?
- Does Context-Aware Access allow access?
- Does the user have a Gmail license?

Only after these checks does Gmail open.

Authentication Flow

User



Identity



Authentication



Authorization



Security Policies



Google Workspace Service

2. Identity

Identity answers:

Who is the user?

Examples

rahul@company.com

alice@company.com

An identity contains information such as:

- Email Address
- Name

- Employee ID
- Department
- OU
- Groups
- License
- Roles

Identity alone does NOT grant access.

Enterprise Example

Employee

Rahul

Identity

rahul@company.com

Department

Engineering

OU

Engineering

Groups

Developers

Project Alpha

License

Enterprise Plus

This identity is stored inside Google Workspace (or synchronized from an external IdP).

3. Authentication

Authentication answers:

Who are you?

The system verifies that the person is really Rahul.

Methods include

- Password
- Passkeys
- Security Keys
- MFA
- SAML
- OpenID Connect

If authentication succeeds,

the user proves their identity.

Authentication Example

Rahul enters

Username

rahul@company.com

Password

Google verifies

Password Hash

↓

Match?

↓

Yes



Authentication Successful

The user is authenticated.

Nothing more.

Authentication Does NOT Mean Access

Many beginners assume:

Authenticated

=

Access Granted

Incorrect.

Authentication only proves identity.

Authorization still needs to occur.

4. Authorization

Authorization answers:

What are you allowed to access?

Examples

Can Rahul

- Access Gmail?
- Access Drive?
- Access Admin Console?
- Reset passwords?
- View audit logs?

These decisions depend on

- Admin Roles
- Groups
- Application assignment
- Policies
- Context

Example

Rahul

Authenticated

↓

Attempts Admin Console

↓

Does Rahul have Admin Role?

↓

No

↓

403 Forbidden

Authentication succeeded.

Authorization failed.

Authentication vs Authorization

Authentication	Authorization
Verifies identity	Determines permissions
Password	Roles

Authentication	Authorization
MFA	Groups
SAML	Policies
Login	Resource Access

Remember

Authentication

↓

Identity

Authorization

↓

Permissions

5. Complete Login Flow

User opens Gmail

↓

Google receives request

↓

Identity located?

↓

No

↓

User does not exist

↓

Stop



Yes



Authentication



Password Correct?



No



Authentication Failed



Yes



MFA Required?



Yes



Verify MFA



Success



Authorization

↓

Application Allowed?

↓

No

↓

403 Forbidden

↓

Yes

↓

Context-Aware Access

↓

Managed Device?

↓

Location Allowed?

↓

Endpoint Verified?

↓

If all policies pass

↓

Gmail Opens

6. Identity Provider (IdP)

An Identity Provider authenticates users.

Examples

- Google Identity
- Microsoft Entra ID
- Okta
- Ping Identity

Responsibilities

- Verify credentials
 - Authenticate users
 - Issue identity assertions or tokens
-

7. Service Provider (SP)

A Service Provider provides the application.

Examples

- Gmail
- Salesforce
- ServiceNow
- Workday
- Slack

Responsibilities

- Trust the IdP
 - Accept authentication
 - Provide application access
-

Example

Okta

↓

Authenticates Rahul

↓

Google trusts Okta



Google opens Gmail

Okta is the Identity Provider.

Google Workspace is the Service Provider.

8. Authentication Factors

Authentication can rely on different factors.

Something you know

- Password
- PIN

Something you have

- Security Key
- Phone
- Passkey-capable device

Something you are

- Fingerprint
- Face Recognition

Enterprise environments commonly combine multiple factors.

9. Multi-Factor Authentication (MFA)

Why MFA?

Passwords can be

- Guessed
- Stolen
- Phished
- Reused

Adding another factor significantly increases security.

Example

Password

+

Security Key

Even if the password is stolen,

the attacker still needs the second factor.

10. Authentication Challenges

Sometimes Google detects unusual activity.

Examples

- New Country
- New Device
- New Browser
- Unusual IP

Google may request additional verification.

Administrators can temporarily disable login challenges for troubleshooting.

Important

This does NOT bypass

- Authorization
- Context-Aware Access
- Security Policies

It only affects Google's additional authentication challenge.

Example

Employee

Travels from India to Singapore.

Google requests

Additional Verification.

Help Desk verifies identity.

Admin

Turns off Login Challenges

↓

User authenticates successfully.

Context-Aware Access still applies.

11. Authentication Troubleshooting

Question

User cannot login.

Where do you begin?

Do NOT randomly reset passwords.

Instead,

identify which layer is failing.

Our Troubleshooting Framework

Always ask

Which layer is failing?

Layer 1

Authentication

Examples

- Wrong Password
- SAML Failure
- MFA Failure
- Login Challenges

Layer 2

Authorization

Examples

- Missing Admin Role
- Application Assignment
- Permission Denied

Layer 3

Context

Examples

- Context-Aware Access
- Device Trust
- Endpoint Verification
- Location Restriction

Layer 4

Provisioning

Examples

- SCIM Failure
- User Missing
- License Missing
- Wrong OU

Layer 5

Application

Examples

- Gmail Disabled
- Drive Policy

- API Configuration
- Calendar Permission

This framework should be your first thought during troubleshooting.

Example Scenarios

Scenario 1

User enters wrong password.

Layer

Authentication

Scenario 2

User signs in successfully.

Admin Console shows

403 Forbidden.

Layer

Authorization

Scenario 3

User signs in.

Admin Console blocked because device is unmanaged.

Layer

Context

Scenario 4

SCIM failed.

User does not exist.

Layer

Provisioning

Scenario 5

User can login,

but Gmail is disabled for their OU.

Layer

Application

Best Practices

- ✓ Always enable MFA.
 - ✓ Use phishing-resistant authentication when possible.
 - ✓ Apply the Principle of Least Privilege.
 - ✓ Use Context-Aware Access for sensitive applications.
 - ✓ Investigate before resetting passwords.
 - ✓ Follow a structured troubleshooting approach.
-

Common Mistakes

- ✗ Assuming authentication equals authorization.
- ✗ Disabling security controls without investigation.
- ✗ Ignoring Context-Aware Access.
- ✗ Granting excessive permissions.

✗ Troubleshooting by trial and error.

Interview Questions

1. What is the difference between Authentication and Authorization?
 2. What is an Identity Provider?
 3. What is a Service Provider?
 4. Why does successful authentication not guarantee access?
 5. Explain your troubleshooting methodology for login issues.
 6. What does "Turn off Login Challenges" do?
 7. Can disabling login challenges bypass Context-Aware Access? Why or why not?
-

Key Takeaways

Identity



Authentication



Authorization



Context



Application Access

Remember

Authentication answers

Who are you?

Authorization answers

What are you allowed to do?

Context answers

Should you be allowed to access this resource under the current conditions?

Thinking in these layers helps you diagnose issues systematically instead of guessing.

Chapter Summary

In this chapter you learned

- ✓ Identity
- ✓ Authentication
- ✓ Authorization
- ✓ Identity Providers
- ✓ Service Providers
- ✓ MFA
- ✓ Login Challenges
- ✓ Structured Troubleshooting

The next chapter covers **SAML 2.0**, including assertions, NameID, ACS URLs, certificates, digital signatures, SP-initiated vs IdP-initiated SSO, common failures, and enterprise troubleshooting.